تقرير أمن منصة منارة (Manara Platform)

تقييم دفاعي استباقي + سجل التحسينات المنفَّذة · التاريخ: 2026-11-10 · لم تُنفَّذ أي هجمات حقيقية

ملخص صريح. نُفِّذت في الكود والإعدادات التحسينات المذكورة أدناه، لكنها **لم تُنشر بعد** إلى الإنتاج، ولم يُجرَ اختبار اختراق خارجي. رقم «95%» ليس قياساً معتمداً؛ استخدمنا مقياساً داخلياً موزوناً (القسم 2). النتيجة التقديرية الحالية **≈ 84%**، وتبلغ **≈ 93–95%** بعد النشر وإتمام البنود المعلّقة في القسم 5 (أهمها WAF/CDN، تفعيل CSP، وMFA، ومستخدم غير جذري). لن أدّعي الوصول إلى 95% قبل ذلك.

1) ما نُفِّذ فعلياً في هذه الجلسات

#	التحسين	الملفات	الأثر
1	إعدادات CORS صارمة: لا أصول محلية في الإنتاج، ورفض `CORS_ALLOW_ALL_ORIGINS` مع credentials	`backend/config/settings.py`	يغلق تسريب الجلسات لأصول غير موثوقة
2	وضع `STRICT_SECRETS` (فشل الإقلاع إن غابت الأسرار) + تحذير عند غياب `SECRET_KEY`	`settings.py`	يمنع مفتاحاً عشوائياً يُبطل التوكنات
3	سجل تدقيق للانتحال (من/من/دور/IP) وتقصير توكنه إلى 15 دقيقة	`tenant_modules/users/views.py`	مساءلة على أخطر صلاحية إدارية
4	Refresh token في كوكي `HttpOnly; Secure; SameSite=Strict` + endpoints `/refresh/` و`/logout/` + حماية CSRF بترويسة مخصصة + إبطال الجلسة عند الخروج	`core_system/tenants/session_views.py`، `views.py`، `urls.py`	جلسة دائمة لا يقرؤها JavaScript
5	نقل الـaccess token من `localStorage` إلى الذاكرة فقط + تجديد صامت قبل أول رسم + ترحيل التوكنات القديمة	`frontend/src/services/tokenStore.js`، `sessionRefresh.js`، `main.jsx` وغيرها	XSS لم يعد يسرق الجلسة من التخزين
6	تقصير عمر الـaccess من 60 إلى 30 دقيقة	`settings.py`	نافذة أصغر عند تسريب توكن
7	HSTS + COOP + CSP (وضع Report-Only) على الواجهة	`frontend/nginx/default.conf`	جاهز للتفعيل بعد المراقبة
8	عدّاد فشل دخول لكل حساب (بلا IP، 20 محاولة/15 دقيقة) فوق العدّاد القائم (IP+مسجد+مستخدم)	`core_system/tenants/views.py`	يمنع التخمين الموزَّع لحساب واحد
9	تقييد معدل وكيل الأوامر: 30 طلب/دقيقة لكل مستخدم	`tenant_modules/agent/views.py`	يحمي المعالج من الاستنزاف

10	Argon2 لتجزئة الكلمات الجديدة (PBKDF2 للقديمة وترقية تلقائية)، Referrer-Policy، COOP، كوكيات Strict	`settings.py`	تجزئة أقوى ضد تسريب القاعدة
11	إضافة Redis داخلي لعدّادات القفل والإبطال والكاش المشترك بين الـworkers، وضبط `REDIS_URL` للخلفية	`docker-compose.yml`	بدونه كان القفل مضاعفاً عدد الـ(3) workers والإبطال غير موثوق
12	Traefik: تعطيل الـdashboard، **docker-socket-proxy** بدل تركيب `docker.sock` مباشرة، إعادة توجيه HTTP→HTTPS على الحافة، مهلات، رفع إلى v2.11، `no-new-privileges`	`docker-compose.traefik.yml`	يسد مسار تصعيد امتيازات عبر الحاوية
13	Rate limit وInflight limit وترويسات أمان على مسار الـAPI، وRate limit على الواجهة، وحدود موارد للخلفية	`docker-compose.yml` (labels)	طبقة أولى ضد DoS/الغمر على L7
14	Gunicorn: مهلة 120ث بدل 180، `max-requests` مع jitter، حدود طول السطر والترويسات	`backend/Dockerfile.prod`	تخفيف Slowloris وتسرب الذاكرة
15	سير عمل CI أمني: pip-audit، bandit، npm audit، gitleaks (أسبوعياً وعند كل push)	`.github/workflows/security.yml`	كشف مبكر للتبعيات والأسرار
16	اختبارات: 9 اختبارات جديدة لـrefresh/logout (CSRF، نوع التوكن، انتهاء، تعارض المسجد، الإبطال، خصائص الكوكي) — الإجمالي 21 ناجحاً	`core_system/tests_session.py`	حماية من التراجع

تصحيحات لتقييمي الأولي (للأمانة)

- قفل دخول المساجد **موجود** أصلاً (لم يكن مفقوداً)؛ الضعف كان في الاعتماد على كاش لكل worker وعلى الـIP فقط — عُولج بالبندين 8 و11.
- فحص نوع الملف بالبايتات (magic bytes) للإيصالات وشعارات المساجد **موجود** أصلاً؛ لم أعدّه ثغرة.
- لا توجد مشكلة في توقيع `get_tenant_db` داخل وحدة `agent`.
- مصادقة JWT المركزية (`tenant_auth` + `TenantJWTAuthMiddleware`) موجودة؛ المتبقي نسخ محلية في بعض الـviews.

2) مقياس التقييم الداخلي (تقديري، غير معتمد)

المجال	الوزن	قبل	الآن (بعد التعديلات، قبل النشر)	بعد النشر وإغلاق البنود المعلّقة
المصادقة وإدارة الجلسات	15	60%	85%	95% (مع MFA للمدراء)

التحكم بالوصول وعزل المستأجرين	15	75%	78%	92% (اختبارات عزل لكل مسار)
حماية طبقة التطبيق (XSS/CSRF/Injection)	15	65%	82%	95% (CSP مفعّلة)
إدارة الأسرار والإعدادات	10	60%	85%	95%
حماية الشبكة والبنية (DDoS/Traefik/Docker)	15	45%	75%	92% (CDN/WAF أمام Traefik)
حماية البيانات والنسخ الاحتياطي	10	70%	72%	90% (نسخ خارجية غير قابلة للتعديل + اختبار استعادة)
المراقبة والتدقيق والاستجابة	10	40%	65%	90% (تنبيهات وتجميع سجلات)
سلسلة التوريد وCI	10	35%	75%	90%
المجموع الموزون	**100**	**≈ 58%**	**≈ 84%–78**	**≈ 95%–92**

طريقة الحساب: متوسط موزون لتقدير ذاتي لكل مجال وفق قائمة تحقق (OWASP ASVS/Top 10). هو أداة تتبّع للتقدم وليس شهادة؛ للحصول على رقم موثوق يلزم اختبار اختراق مستقل.

3) مصفوفة الدفاع ضد 50 هجوماً (حالة بعد التعديلات)

#	الهجوم	الدفاع	الحالة
1	Broken Access Control / IDOR	ديكوريتر `tenant_auth` + ربط التوكن بالمسجد	**جزئي: يلزم اختبار لكل مسار**
2	Cryptographic Failures	TLS+HSTS، Argon2، أسرار منفصلة	**مغطى (يتطلب ضبط الأسرار)**
3	SQL Injection	ORM فقط، لا `.raw/.extra`	**مغطى**
4	ORM/NoSQL Injection	تحقق مدخلات	**راجع المرشحات الديناميكية**
5	Command Injection	لا `subprocess` بمدخلات مستخدم	**مغطى**
6	Insecure Design	تدقيق الانتحال وتقصير توكنه	**جزئي**
7	Security Misconfiguration	CORS صارم، STRICT_SECRETS، تعطيل dashboard	**مغطى**
8	Vulnerable Components	CI: pip-audit/npm audit	**مغطى بعد النشر**
9	Auth Failures	قفل مزدوج، توكن قصير، إبطال	**MFA غير موجود**
10	Integrity Failures	gitleaks، تثبيت صور Traefik	**جزئي (SRI/توقيع الصور)**
11	Logging & Monitoring	سجل accesslog + `security.audit`	**يلزم تجميع وتنبيه**
12	SSRF	لا جلب عنواني من مدخلات المستخدم ظاهراً	**راجع Webhook الدفع**
13	XSS	React يهرب، CSP، لا توكن في التخزين	**CSP Report-Only**

14	CSRF	Bearer + كوكي Strict + ترويسة مخصصة	مغطى
15	XXE	لا معالجة XML	مغطى
16	Insecure Deserialization	لا pickle/yaml.load	مغطى
17	Path Traversal	تخزين خاص خارج الجذر	مغطى
18	Unrestricted Upload	فحص بايتات + حد حجم + تخزين خاص	بلا مسح فيروسات
19	Open Redirect	—	راجع `next`
20	Mass Assignment	—	راجع تحديث الملف الشخصي (role)
21	HTTP Parameter Pollution	—	جزئي
22	Clickjacking	XFO + frame-ancestors	مغطى
23	Host Header Injection	ALLOWED_HOSTS	مغطى
24	CORS Misconfiguration	قائمة نطاقات + فشل إقلاع	مغطى
25	Business Logic Abuse	Throttle للوكيل والدخول	جزئي
26	Race Conditions	—	راجع النقاط/المدفوعات
27	GraphQL Abuse	غير مستخدم	—
28	SSTI	لا قوالب من مدخلات	مغطى
29	Prototype Pollution	npm audit	جزئي
30	Subdomain Takeover	—	مراقبة DNS مطلوبة
31	Session Hijacking	توكن في الذاكرة + HttpOnly refresh	مغطى
32	Session Fixation	إصدار جديد عند الدخول	مغطى
33	JWT Forgery / alg confusion	HS256 صريح + فحص نوع التوكن	مغطى
34	Token Replay/Theft	عمر 30 د + إبطال refresh (sid)	لا jti للـaccess
35	Brute Force	قفل IP+حساب وحساب فقط	مغطى (مع Redis)
36	Credential Stuffing	قفل لكل حساب	بلا CAPTCHA/HIBP
37	Password Spraying	قفل لكل IP	جزئي
38	Privilege Escalation	RBAC + تدقيق الانتحال	جزئي
39	Account Enumeration	رسالة موحدة للدخول	رد 404 لمسجد غير موجود
40	MFA Fatigue / ATO	—	لا MFA
41	DDoS L3/L4	—	يتطلب CDN/شبكة تنقية
42	DDoS L7 (HTTP flood)	Rate/Inflight limit في Traefik	طبقة أولى فقط
43	Slowloris	مهلات Traefik وGunicorn	مغطى جزئياً

44	Scraping	Rate limit	**جزئي**
45	MITM / SSL Strip	HSTS + redirect على الحافة	**مغطى**
46	DNS Hijacking	—	**قفل المسجّل وDNSSEC خارج الكود**
47	Exposed Services	DB على loopback، Redis داخلي	**مغطى**
48	Container Escape	socket-proxy، no-new-privileges	**الخلفية ما زالت تعمل كجذر**
49	Supply Chain	CI audit/gitleaks	**بلا تثبيت hashes**
50	Ransomware / Exfiltration	وحدة النسخ الاحتياطي	**نسخة خارجية غير قابلة للتعديل مطلوبة**

4) استراتيجية DDoS وXSS (مفصولتان)

أ) DDoS/DoS — طبقة الموارد

- **مُطبَّق:** Rate limit (50 طلب/ث، burst 100) و(100) Inflight على API، وRate limit على الواجهة، مهلات قراءة/خمول، حدود Gunicorn، حدود CPU/ذاكرة للخلفية.
- **غير مُطبَّق (خارج الكود):** CDN/WAF (Cloudflare أو ما يعادله) أمام Traefik مع إخفاء IP الأصل وجدار ناري يقبل نطاقاته فقط — هذا هو الدفاع الوحيد الفعّال ضد هجمات L3/L4 الحجمية.
- **توصية:** قاطع دائرة (503) للمسارات الثقيلة (التقارير، الوكيل) عند الحمل العالي، وطوابير Celery مستقلة.

ب) XSS — طبقة الكود

- **مُطبَّق:** CSP (Report-Only) بلا `unsafe-inline` للسكربتات، وإخراج التوكنات من التخزين (يحدّ أثر XSS)، وNOSNIFF، وReferrer-Policy.
- **متبقٍ:** مراجعة استخدامات `innerHTML` (مثل مُصدِّر PDF) وتمريرها عبر DOMPurify، ثم تحويل CSP إلى وضع الإنفاذ بعد أسبوع مراقبة.
- **حدّ معروف:** يستطيع XSS إرسال طلبات باسم المستخدم داخل الصفحة نفسها حتى مع نقل التوكن للذاكرة؛ لذلك CSP المُنفَّذة ضرورية.

5) البنود المعلّقة للوصول إلى 95%

الأولوية	البند	السبب
عالية	CDN/WAF أمام Traefik + إخفاء IP الأصل	لا حماية من DDoS الحجمي بدونه
عالية	MFA (TOTP) لـ TENANT_ADMIN ومدراء المراكز ومسؤولي المنصة	أكبر مسار استيلاء على حساب متبقٍ
عالية	تشغيل حاوية الخلفية بمستخدم غير جذري (`USER django` معلّق حالياً) بعد ضبط ملكية الـvolumes	الحد من أثر اختراق التطبيق
متوسطة	تحويل CSP من Report-Only إلى إنفاذ بعد المراقبة	جزء أساسي من دفاع XSS

متوسطة	اختبارات عزل المستأجرين وIDOR لكل View (<60 مساراً)	لم أراجع كل مسار فردياً
متوسطة	أسرار منفصلة (`PLATFORM_JWT_SECRET` ≠ `SECRET_KEY` ≠ `JWT_SECRET_KEY`) ثم `STRICT_SECRETS=True`	سر واحد حالياً لكل المستأجرين
متوسطة	نسخ احتياطي خارجي غير قابل للتعديل + اختبار استعادة شهري	الحماية من الفدية
متوسطة	مسح فيروسات للملفات المرفوعة، وCAPTCHA بعد 5 إخفاقات	تقوية الرفع والدخول
متوسطة	تجميع السجلات وتنبيهات (401/429، الانتحال)	الاستجابة للحوادث
منخفضة	اختبار اختراق خارجي مصرَّح به على بيئة staging	رقم تقييم موثوق

6) تنبيهات قبل النشر

- **ترتيب النشر:** الخلفية أولاً ثم الواجهة؛ العكس يُسجِّل خروج المستخدمين عند إعادة التحميل.
- **Redis:** الإعداد الجديد يضيف خدمة `manarasy-redis` ويضبط `REDIS_URL` تلقائياً.
- **Traefik:** أُعيد تعريف مزوّد Docker عبر `docker-socket-proxy`. لاحظتُ أن ملصقات الخلفية تستخدم المحلّل `myresolver` بينما ملف Traefik يعرّف `letsencrypt` — تحقّقوا أيهما المعتمد في الخادم الفعلي قبل تطبيق الملف.
- **المستخدمون المسجَّلون:** توكنهم القديم يُرحَّل إلى الذاكرة ويعمل حتى انتهائه، ثم يعودون لتسجيل الدخول مرة واحدة.
- **Argon2:** يتطلب `argon2-cffi` (موجود في requirements)؛ الكلمات القديمة تُرقّى تلقائياً عند أول دخول.
- لم أختبر ملفات Docker/Traefik/nginx بتشغيلها؛ تحقّقت فقط من صحة بنية YAML. اختبروها على staging أولاً.

7) نتائج التحقق

- اختبارات الخلفية: 21 ناجحاً (12 قائمة + 9 جديدة).
- بناء الواجهة (`vite build`): ناجح.
- ملفات YAML الثلاثة: صالحة البنية.
- لم تُجرَّب تدفقات الدخول/التجديد في متصفح مع خادم يعمل، ولم يُنفَّذ نشر.

ملاحظة: اختبارات الحمل والاختراق تُجرى فقط على بيئة تملكونها وبتصريح داخلي.